CIA Part 1 – Questions 60–118

Governance, Risk, Controls, Ethics, IT, Fraud & QAIP

CIA Study Prep

October 17, 2026

Instructions

Each question slide is followed by a separate answer/explanation slide.

Questions are written at or above real exam difficulty.

Distractors are designed to be plausible; read every word carefully.

Q60

Question: The CAE of a listed company is preparing the annual audit plan. The audit committee has requested that internal audit cover "all significant risks." During planning, the CAE learns that management's risk register omits several risks related to a new digital lending platform (cyber, model risk, third-party data privacy), and that the platform is expected to generate 35% of revenue within 18 months. The CAE also learns that the platform's vendor has not provided a SOC 2 report and that no internal audit work has been done on the platform. Which action is MOST consistent with the Standards?

A. Rely on management's risk register because it is the approved risk document; schedule the platform for a future cycle.

B. Include the platform risks in the audit universe, perform a risk assessment, prioritize coverage, and coordinate with other assurance providers.

C. Defer planning until the vendor provides a SOC 2 report and management updates the risk register.

D. Assign the platform audit to the IT vendor's internal auditors to leverage their expertise.

Q60 – Answer & Explanation

Correct Answer: B

Why: Standards 2010/2010.A1/2010.A2 require the CAE to consider the organization's risk profile, including emerging risks, and to develop a risk-based plan. A material new platform with unmitigated risks must be assessed and covered.

A wrong: The risk register is an input, not the sole basis; emerging risks must be considered.

C wrong: Waiting for the vendor or management delays assurance on a material risk.

D wrong: The vendor's auditors are not independent of the vendor and cannot provide objective assurance to the organization.

Q61

Question: During an engagement, an auditor discovers that the CFO has been directing large "consulting" payments to a company owned by a close friend, and that the CFO approved the related contracts. The auditor's draft report includes this finding. The CEO asks the auditor to "hold the finding" until the CFO's upcoming retirement, to "avoid embarrassment." Which action is MOST appropriate?

A. Hold the finding as requested because the CFO is retiring soon.

B. Report the finding promptly and escalate the CEO's request to the audit committee or board.

C. Report the finding to the external auditor only.

D. Remove the CFO's name from the finding but keep the finding.

Q61 – Answer & Explanation

Correct Answer: B

Why: Integrity/Objectivity (Code) and Standard 2600 require prompt reporting of significant issues, including potential fraud/conflict of interest, to the board/audit committee. Suppression is prohibited.

A wrong: Retirement timing does not justify delaying a significant finding.

C wrong: Reporting only to external audit does not satisfy board reporting.

D wrong: Removing the name does not cure the suppression or the substance.

Q62

Question: An auditor is testing the operating effectiveness of a control requiring two approvals for new vendor additions. The auditor selects a sample of 50 vendor additions and finds that 3 were approved by only one person. The auditor also finds that the system does not log approvals, so the audit trail is incomplete. Which conclusion is MOST appropriate?

A. The control is effective because 47 of 50 were properly approved.

B. The control is not operating effectively; deviations exist and the lack of an audit trail impairs evidence of operation.

C. The control is effective because the deviations were "only 3."

D. The auditor should accept the control because management approved the process.

Q62 – Answer & Explanation

Correct Answer: B

Why: Deviations indicate the control is not consistently operating, and the missing audit trail undermines evidence of operation (Standard 2300). This should be reported.

A wrong: Any deviation matters, especially for a key control.

C wrong: "Only 3" is not an acceptable rationale.

D wrong: Management approval of the process does not validate operation.

Q63

Question: The CAE is evaluating whether the internal audit activity's QAIP is effective. The activity has ongoing internal assessments, a periodic internal assessment performed last year, but the last external assessment was seven years ago and the CAE has not disclosed the nonconformance to the board. Which statement is MOST accurate?

A. The QAIP is effective because internal assessments are current.

B. The QAIP is nonconforming; Standard 1312 requires an external assessment at least every five years, and Standard 1320 requires disclosure of nonconformance to the board.

C. The external assessment is optional if internal assessments are clean.

D. The QAIP is effective because no significant issues were found internally.

Q63 – Answer & Explanation

Correct Answer: B

Why: Standard 1312 requires external assessment at least every five years; Standard 1320 requires reporting nonconformance to senior management and the board.

A wrong: Internal assessments do not replace external assessment.

C wrong: External assessment is mandatory.

D wrong: Clean internal assessments do not waive the requirement.

Q64

Question: An auditor is testing the completeness of recorded revenue. The auditor traces a sample of shipping documents to sales invoices and finds that 10% of shipments were invoiced in the following period. Management states that revenue was recorded when the customer accepted the goods, not when shipped. The auditor reviews the sales contracts and finds that control transfers at shipment. Which conclusion is MOST appropriate?

A. Revenue is complete because management's policy is consistent.

B. Revenue is likely understated; control transferred at shipment, so revenue should have been recorded earlier.

C. Revenue is overstated because invoices were issued late.

D. The auditor should accept management's policy because it is documented.

Q64 – Answer & Explanation

Correct Answer: B

Why: Revenue recognition follows transfer of control. If contracts specify shipment, recording at customer acceptance understates revenue in the period.

A wrong: Consistency with a wrong policy does not make it correct.

C wrong: Late invoicing indicates understatement, not overstatement.

D wrong: Documentation does not override the contractual terms.

Q65

Question: The CAE is asked to assess the organization's governance of a joint venture in a foreign country. The joint venture has a local board, but the organization has only one representative, who is also the CFO, and the CFO has signing authority for all transactions. Which conclusion is MOST appropriate?

A. Governance is adequate because the organization has a board representative.

B. Governance is deficient; concentrating board representation and signing authority in one executive impairs oversight and creates a significant control risk.

C. Joint venture governance is outside internal audit's scope.

D. The auditor should ignore the issue because it is a foreign jurisdiction.

Q65 – Answer & Explanation

Correct Answer: B

Why: Effective governance requires independent oversight and segregation of duties. Concentrating board representation and signing authority in one executive (especially the CFO) is a significant governance/control weakness.

A wrong: A single representative is not adequate oversight.

C wrong: Joint ventures are within internal audit's scope.

D wrong: Foreign jurisdiction does not exempt governance review.

Q66

Question: An auditor is evaluating the organization's fraud risk assessment for the sales function. Management identifies "fictitious sales" as a risk but has no controls to address it and no monitoring. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because the risk was identified.

B. The fraud risk assessment is incomplete; identified risks require controls and monitoring to be effectively managed.

C. Fraud risk assessment is not required for sales.

D. The auditor should ignore the lack of controls because management identified the risk.

Q66 – Answer & Explanation

Correct Answer: B

Why: Identifying a risk without controls or monitoring does not manage it. The assessment should be linked to responses and monitoring.

A wrong: Identification alone is insufficient.

C wrong: Sales is a high-fraud-risk area requiring assessment.

D wrong: Lack of controls is a reportable weakness.

Q67

Question: The CAE is evaluating whether the organization's internal audit activity has sufficient authority. The charter grants unrestricted access to records, personnel, and property, and the audit committee approves the charter and plan. However, management has told staff not to cooperate with internal audit without management approval. Which conclusion is MOST appropriate?

A. Authority is adequate because the charter grants unrestricted access.

B. Authority is impaired in practice; management's instruction undermines the charter and internal audit's ability to perform engagements.

C. Authority is adequate because the audit committee approves the plan.

D. Authority is not relevant to internal audit.

Q67 – Answer & Explanation

Correct Answer: B

Why: Authority must be both granted (charter) and respected in practice. Management's instruction not to cooperate impairs internal audit's ability to perform and should be escalated.

A wrong: Charter authority is undermined by practice.

C wrong: Plan approval does not ensure cooperation.

D wrong: Authority is essential.

Q68

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q68 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q69

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q69 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q70

Question: An auditor is assessing the organization's third-party risk management for a critical cloud provider. The provider has a SOC 2 Type II report, but the report covers a period ending 14 months ago and the provider has since changed its subservice providers. Which conclusion is MOST appropriate?

A. The SOC 2 report is sufficient because it is a Type II report.

B. The SOC 2 report is stale and does not cover recent subservice provider changes; the organization should obtain updated assurance and assess the changes.

C. SOC 2 reports are irrelevant to internal audit.

D. The organization should terminate the provider immediately.

Q70 – Answer & Explanation

Correct Answer: B

Why: SOC 2 Type II covers a period; a 14-month-old report and subsequent subservice changes reduce its relevance. Updated assurance is needed.

A wrong: Type II is useful but must be current and cover relevant changes.

C wrong: SOC reports are relevant evidence.

D wrong: Termination is an overreaction; remediation/updated assurance is appropriate.

Q71

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of the audit function. The board receives audit reports but has no charter, no independent audit committee, and the CEO approves the CAE's performance evaluation. Which conclusion is MOST appropriate?

A. Oversight is effective because the board receives audit reports.

B. Oversight is deficient; lack of a charter, independent audit committee, and CEO-controlled CAE evaluation impair internal audit independence and board oversight.

C. Oversight is effective because the CEO is accountable.

D. Oversight is outside internal audit's scope.

Q71 – Answer & Explanation

Correct Answer: B

Why: Internal audit independence requires a board-approved charter, functional reporting to an independent audit committee, and CAE evaluation by the board. CEO-controlled evaluation impairs independence.

A wrong: Receiving reports is not effective oversight.

C wrong: CEO accountability does not ensure independence.

D wrong: Internal audit assesses governance.

Q72

Question: An auditor is testing the organization's controls over the use of artificial intelligence (AI) in credit decisions. The auditor finds that the AI model was developed by an external vendor, has not been validated, and that management cannot explain the model's logic. Which conclusion is MOST appropriate?

A. Controls are adequate because the model was developed by a vendor.

B. Controls are deficient; unvalidated AI models with unexplainable logic create significant model, compliance, and reputational risk.

C. AI models do not require validation.

D. The auditor should not assess AI models.

Q72 – Answer & Explanation

Correct Answer: B

Why: AI models used in credit decisions require validation, documentation, and explainability to manage model risk and regulatory compliance.

A wrong: Vendor development does not eliminate the need for validation.

C wrong: AI models require validation.

D wrong: AI risk is a core internal audit area.

Q73

Question: The CAE is evaluating the organization's fraud hotline. The hotline is managed by the internal audit function, reports go directly to the CAE, and the CAE investigates all reports. Which statement is MOST accurate?

A. The hotline is effective because internal audit is independent.

B. The hotline may create an independence/self-review issue if internal audit investigates reports about its own function; oversight by the audit committee is important.

C. The hotline is ineffective because internal audit manages it.

D. Hotlines should never be managed by internal audit.

Q73 – Answer & Explanation

Correct Answer: B

Why: Internal audit managing a hotline is common, but reports involving internal audit itself create a self-review threat. Audit committee oversight and escalation protocols are important safeguards.

A wrong: Independence alone does not resolve self-review for reports about internal audit.

C wrong: Internal audit management is not inherently ineffective.

D wrong: Internal audit can manage hotlines with safeguards.

Q74

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the controller prepares, reviews, and posts consolidation entries, and that the controller has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q74 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

B wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q75

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q75 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

B wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q76

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q76 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q77

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q77 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q78

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q78 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q79

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q79 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q80

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q80 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q81

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q81 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q82

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q82 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q83

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q83 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

Q84

Question: An auditor is testing the organization's controls over the sales commission process. The auditor finds that sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

Q84 – Answer & Explanation

Correct Answer: B

Why: The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

A wrong: Knowledge is not a control.

C wrong: Rarity does not reduce the fraud risk.

D wrong: Commissions are a core audit area.

Q85

Question: The CAE is evaluating the organization's compliance with its own code of conduct. The CAE finds that senior executives routinely accept expensive gifts from vendors and that no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

Q85 – Answer & Explanation

Correct Answer: B

Why: Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

A wrong: A written code without enforcement is ineffective.

C wrong: Expensive gifts create significant conflicts.

D wrong: Executive behavior is a key governance indicator.

Q86

Question: An auditor is assessing the organization's controls over the use of spreadsheets in financial reporting. The auditor finds that a critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

Q86 – Answer & Explanation

Correct Answer: B

Why: Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

A wrong: Common use does not reduce risk.

C wrong: Spreadsheets can be used with adequate controls.

D wrong: Spreadsheet controls are a valid audit area.

Q87

Question: The CAE is evaluating the organization's risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

Q87 – Answer & Explanation

Correct Answer: B

Why: Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.

A wrong: CIO accountability alone is insufficient.

C wrong: All projects require risk management.

D wrong: IT project risk is a core audit area.

Q88

Question: An auditor is testing the organization's controls over journal entries. The auditor finds that 20 large manual entries were posted at year-end by the controller with descriptions such as "reclass" and "true-up," and that supporting documentation cannot be located. Which action is MOST appropriate?

A. Accept the entries because the controller is authorized.

B. Investigate the entries, request support, and report the lack of documentation as a significant deficiency.

C. Delete the entries from the system.

D. Ignore the entries because they are year-end adjustments.

Q88 – Answer & Explanation

Correct Answer: B

Why: Large manual year-end entries by senior management are a high fraud risk area. Lack of support is a significant deficiency requiring investigation and reporting.

A wrong: Authorization does not eliminate the need for support.

C wrong: Internal audit should not alter records.

D wrong: Year-end adjustments require documentation.

Q89

Question: The CAE is evaluating the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

Q89 – Answer & Explanation

Correct Answer: B

Why: KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

A wrong: Financial/customer metrics alone are insufficient.

C wrong: KRIs are an important monitoring tool.

D wrong: Internal audit assesses risk monitoring.

Q90

Question: An auditor is evaluating the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q90 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q91

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q91 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q92

Question: An auditor is testing the organization's controls over the use of artificial intelligence (AI) in credit decisions. The auditor finds that the AI model was developed by an external vendor, has not been validated, and that management cannot explain the model's logic. Which conclusion is MOST appropriate?

A. Controls are adequate because the model was developed by a vendor.

B. Controls are deficient; unvalidated AI models with unexplainable logic create significant model, compliance, and reputational risk.

C. AI models do not require validation.

D. The auditor should not assess AI models.

Q92 – Answer & Explanation

Correct Answer: B

Why: AI models used in credit decisions require validation, documentation, and explainability to manage model risk and regulatory compliance.

A wrong: Vendor development does not eliminate the need for validation.

C wrong: AI models require validation.

D wrong: AI risk is a core internal audit area.

Q93

Question: The CAE is evaluating the organization's fraud hotline. The hotline is managed by the internal audit function, reports go directly to the CAE, and the CAE investigates all reports. Which statement is MOST accurate?

A. The hotline is effective because internal audit is independent.

B. The hotline may create an independence/self-review issue if internal audit investigates reports about its own function; oversight by the audit committee is important.

C. The hotline is ineffective because internal audit manages it.

D. Hotlines should never be managed by internal audit.

Q93 – Answer & Explanation

Correct Answer: B

Why: Internal audit managing a hotline is common, but reports involving internal audit itself create a self-review threat. Audit committee oversight and escalation protocols are important safeguards.

A wrong: Independence alone does not resolve self-review for reports about internal audit.

C wrong: Internal audit management is not inherently ineffective.

D wrong: Internal audit can manage hotlines with safeguards.

Q94

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the controller prepares, reviews, and posts consolidation entries, and that the controller has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q94 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q95

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q95 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q96

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q96 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q97

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q97 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q98

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q98 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

Q99

Question: The CAE is assessing the organization's internal control framework. The organization has a strong control environment and strong control activities but no monitoring activities and no information/communication process. Which conclusion is MOST appropriate?

A. The internal control framework is effective because the control environment and activities are strong.

B. The internal control framework is incomplete; all five COSO components (including monitoring and information/communication) are necessary.

C. Monitoring and information/communication are optional.

D. Only control activities matter.

Q99 – Answer & Explanation

Correct Answer: B

Why: COSO requires all five components: control environment, risk assessment, control activities, information/communication, and monitoring. Missing components make the framework incomplete.

A wrong: Two components do not make a complete framework.

C wrong: All components are required.

D wrong: Control activities alone are insufficient.

Q100

Question: An auditor is testing the organization's controls over the purchase of consulting services. The auditor finds that the same manager selects the consultant, negotiates the contract, approves the invoice, and confirms receipt of services, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because the manager is accountable for results.

B. Controls are deficient; the manager has incompatible duties (selection, negotiation, approval, receipt) with no independent review.

C. Controls are effective because consulting services are intangible.

D. The auditor should not assess consulting purchases.

Q100 – Answer & Explanation

Correct Answer: B

Why: Combining selection, negotiation, approval, and receipt of services creates a significant segregation-of-duties weakness and fraud risk.

A wrong: Accountability is not a control.

C wrong: Intangibility does not reduce the need for controls.

D wrong: Consulting purchases are a legitimate audit area.

Q101

Question: The CAE is evaluating the organization's risk response to a significant cybersecurity risk. Management has purchased cyber insurance but has not implemented basic security controls (patching, access management, monitoring). Which conclusion is MOST appropriate?

A. The risk response is adequate because insurance transfers the risk.

B. The risk response is inadequate; insurance transfers financial impact but does not reduce the likelihood of a breach, and basic controls are missing.

C. Insurance eliminates the need for controls.

D. Cybersecurity risk is not an internal audit concern.

Q101 – Answer & Explanation

Correct Answer: B

Why: Insurance is a risk-sharing response, not a substitute for preventive/detective controls. Basic security controls are essential to reduce likelihood.

A wrong: Insurance does not prevent breaches.

C wrong: Insurance does not eliminate the need for controls.

D wrong: Cybersecurity is a core internal audit area.

Q102

Question: An auditor is assessing the organization's use of a whistleblower hotline. The hotline is outsourced to an independent provider, reports go directly to the audit committee, and the audit committee reviews all reports. However, no reports have been filed in two years, and employee surveys indicate fear of retaliation. Which conclusion is MOST appropriate?

A. The hotline is effective because it is independent and reports to the audit committee.

B. The hotline may be underutilized due to fear of retaliation; the organization should address the retaliation risk and promote the hotline.

C. Zero reports prove the organization is ethical.

D. The auditor should ignore employee surveys.

Q102 – Answer & Explanation

Correct Answer: B

Why: A hotline's effectiveness depends on trust and non-retaliation. Zero reports combined with fear of retaliation suggests underutilization and a culture problem.

A wrong: Structure alone is insufficient.

C wrong: Zero reports may indicate fear, not ethics.

D wrong: Surveys provide relevant culture evidence.

Q103

Question: The CAE is asked to evaluate whether the organization's board has effective oversight of risk. The board receives a quarterly risk report that is prepared by management and contains only risk status ("green") with no details on emerging risks or risk appetite breaches. Which conclusion is MOST appropriate?

A. Board risk oversight is effective because the board receives a quarterly report.

B. Board risk oversight is likely ineffective; the report lacks detail, emerging risks, and appetite breach information.

C. Risk reporting is management's responsibility, not the board's.

D. The auditor should not assess board risk oversight.

Q103 – Answer & Explanation

Correct Answer: B

Why: Effective board risk oversight requires transparent, detailed reporting on emerging risks and appetite breaches. A "green-only" summary impairs oversight.

A wrong: Receiving a report is not the same as effective oversight.

C wrong: The board is responsible for oversight.

D wrong: Internal audit assesses governance/risk oversight.

Q104

Question: An auditor is testing the organization's controls over the sales commission process. The auditor finds that sales managers can adjust commission rates and approve their own adjustments, with no independent review. Which conclusion is MOST appropriate?

A. Controls are effective because sales managers understand commissions.

B. Controls are deficient; sales managers can adjust rates and approve their own changes, creating a significant fraud risk.

C. Controls are effective because commission adjustments are rare.

D. The auditor should not assess sales commissions.

Q104 – Answer & Explanation

Correct Answer: B

Why: The ability to adjust rates and self-approve creates a significant fraud risk (self-dealing). Independent review is required.

A wrong: Knowledge is not a control.

C wrong: Rarity does not reduce the fraud risk.

D wrong: Commissions are a core audit area.

Q105

Question: The CAE is evaluating the organization's compliance with its own code of conduct. The CAE finds that senior executives routinely accept expensive gifts from vendors and that no one has been disciplined. Which conclusion is MOST appropriate?

A. The code of conduct is effective because it is written.

B. The code of conduct is not effective; senior executive behavior and lack of enforcement undermine the code.

C. Gifts are acceptable if they are expensive.

D. The auditor should ignore executive behavior.

Q105 – Answer & Explanation

Correct Answer: B

Why: Tone at the top and enforcement are essential. Senior executives accepting gifts without consequences undermine the code's effectiveness.

A wrong: A written code without enforcement is ineffective.

C wrong: Expensive gifts create significant conflicts.

D wrong: Executive behavior is a key governance indicator.

Q106

Question: An auditor is assessing the organization's controls over the use of spreadsheets in financial reporting. The auditor finds that a critical revenue calculation is performed in a spreadsheet with no version control, no formula documentation, and no independent review. Which conclusion is MOST appropriate?

A. Controls are adequate because spreadsheets are common tools.

B. Controls are deficient; critical spreadsheets require version control, documentation, and independent review.

C. Spreadsheets are always inappropriate for financial reporting.

D. The auditor should not assess spreadsheet controls.

Q106 – Answer & Explanation

Correct Answer: B

Why: Critical spreadsheets are high-risk end-user computing tools requiring version control, documentation, and review to prevent errors/fraud.

A wrong: Common use does not reduce risk.

C wrong: Spreadsheets can be used with adequate controls.

D wrong: Spreadsheet controls are a valid audit area.

Q107

Question: The CAE is evaluating the organization's risk management for a major IT system implementation. The project has no risk register, no steering committee, and no independent oversight; the project manager reports only to the CIO. Which conclusion is MOST appropriate?

A. Project risk management is adequate because the CIO is accountable.

B. Project risk management is deficient; major IT projects require a risk register, steering committee, and independent oversight.

C. IT projects do not require risk management.

D. The auditor should not assess IT project risk.

Q107 – Answer & Explanation

Correct Answer: B

Why: Major IT projects require structured risk management, governance (steering committee), and independent oversight to manage cost, schedule, and risk.

A wrong: CIO accountability alone is insufficient.

C wrong: All projects require risk management.

D wrong: IT project risk is a core audit area.

Q108

Question: An auditor is testing the organization's controls over journal entries. The auditor finds that 20 large manual entries were posted at year-end by the controller with descriptions such as "reclass" and "true-up," and that supporting documentation cannot be located. Which action is MOST appropriate?

A. Accept the entries because the controller is authorized.

B. Investigate the entries, request support, and report the lack of documentation as a significant deficiency.

C. Delete the entries from the system.

D. Ignore the entries because they are year-end adjustments.

Q108 – Answer & Explanation

Correct Answer: B

Why: Large manual year-end entries by senior management are a high fraud risk area. Lack of support is a significant deficiency requiring investigation and reporting.

A wrong: Authorization does not eliminate the need for support.

C wrong: Internal audit should not alter records.

D wrong: Year-end adjustments require documentation.

Q109

Question: The CAE is evaluating the organization's use of key risk indicators (KRIs). The organization tracks revenue, profit, and customer satisfaction but has no KRIs for compliance, cybersecurity, or supply chain risk. Which conclusion is MOST appropriate?

A. KRI coverage is adequate because financial and customer metrics are tracked.

B. KRI coverage is incomplete; the organization lacks KRIs for significant risk areas (compliance, cybersecurity, supply chain).

C. KRIs are optional for all organizations.

D. The auditor should not assess KRIs.

Q109 – Answer & Explanation

Correct Answer: B

Why: KRIs should cover the organization's significant risks. Omitting compliance, cybersecurity, and supply chain KRIs leaves key risks unmonitored.

A wrong: Financial/customer metrics alone are insufficient.

C wrong: KRIs are an important monitoring tool.

D wrong: Internal audit assesses risk monitoring.

Q110

Question: An auditor is evaluating the organization's controls over the financial close. The auditor finds that the same individual prepares, reviews, and posts consolidation entries, and that the individual has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the individual is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q110 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q111

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q111 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q112

Question: An auditor is testing the organization's controls over the use of artificial intelligence (AI) in credit decisions. The auditor finds that the AI model was developed by an external vendor, has not been validated, and that management cannot explain the model's logic. Which conclusion is MOST appropriate?

A. Controls are adequate because the model was developed by a vendor.

B. Controls are deficient; unvalidated AI models with unexplainable logic create significant model, compliance, and reputational risk.

C. AI models do not require validation.

D. The auditor should not assess AI models.

Q112 – Answer & Explanation

Correct Answer: B

Why: AI models used in credit decisions require validation, documentation, and explainability to manage model risk and regulatory compliance.

A wrong: Vendor development does not eliminate the need for validation.

C wrong: AI models require validation.

D wrong: AI risk is a core internal audit area.

Q113

Question: The CAE is evaluating the organization's fraud hotline. The hotline is managed by the internal audit function, reports go directly to the CAE, and the CAE investigates all reports. Which statement is MOST accurate?

A. The hotline is effective because internal audit is independent.

B. The hotline may create an independence/self-review issue if internal audit investigates reports about its own function; oversight by the audit committee is important.

C. The hotline is ineffective because internal audit manages it.

D. Hotlines should never be managed by internal audit.

Q113 – Answer & Explanation

Correct Answer: B

Why: Internal audit managing a hotline is common, but reports involving internal audit itself create a self-review threat. Audit committee oversight and escalation protocols are important safeguards.

A wrong: Independence alone does not resolve self-review for reports about internal audit.

C wrong: Internal audit management is not inherently ineffective.

D wrong: Internal audit can manage hotlines with safeguards.

Q114

Question: An auditor is testing the organization's controls over the financial close. The auditor finds that the controller prepares, reviews, and posts consolidation entries, and that the controller has system access to override the consolidation. Which conclusion is MOST appropriate?

A. Controls are effective because the controller is experienced.

B. Controls are deficient; incompatible duties and override access create a significant risk of undetected error/fraud.

C. Controls are effective because consolidation is routine.

D. The auditor should not assess the financial close.

Q114 – Answer & Explanation

Correct Answer: B

Why: Combining prepare/review/post and override access is a severe segregation-of-duties and override risk.

A wrong: Experience is not a control.

C wrong: Routine processes can still be manipulated.

D wrong: Financial close is a core audit area.

Q115

Question: The CAE is evaluating the organization's risk appetite for cybersecurity. The board has stated "zero tolerance for data breaches," but management has not funded basic security controls and has accepted known vulnerabilities. Which conclusion is MOST appropriate?

A. Risk appetite and behavior are aligned because the board stated zero tolerance.

B. There is a disconnect between stated risk appetite and actual behavior; the organization is not resourcing controls consistent with its appetite.

C. Cybersecurity risk is not a governance issue.

D. The auditor should ignore the disconnect.

Q115 – Answer & Explanation

Correct Answer: B

Why: Risk appetite must be supported by resources and actions. A stated zero tolerance without funding/controls indicates misalignment and a weak risk culture.

A wrong: Statements without action are not alignment.

C wrong: Cybersecurity is a governance risk.

D wrong: Misalignment is a reportable governance weakness.

Q116

Question: An auditor is testing the organization's controls over related-party transactions. The auditor finds that the CEO's spouse owns a consulting firm that received $3 million in contracts, and that the transactions were not disclosed to the board or in the financial statements. Which conclusion is MOST appropriate?

A. The transactions are acceptable because the firm is competitive.

B. The transactions represent a significant control and disclosure deficiency; related-party transactions must be identified, approved, and disclosed.

C. Related-party transactions are outside the scope of internal audit.

D. The auditor should ignore the transactions because they involve a spouse.

Q116 – Answer & Explanation

Correct Answer: B

Why: Related-party transactions require identification, independent approval, and disclosure. Undisclosed transactions with the CEO's spouse's firm are a significant governance/control failure.

A wrong: Competitiveness does not eliminate disclosure requirements.

C wrong: Related-party transactions are a core audit area.

D wrong: Spousal relationships can be fraud indicators.

Q117

Question: The CAE is evaluating the organization's cybersecurity governance. The organization has no board-level cybersecurity expertise, no regular cybersecurity reporting to the board, and no incident response plan. Which conclusion is MOST appropriate?

A. Cybersecurity governance is adequate because IT handles security.

B. Cybersecurity governance is deficient; board oversight, regular reporting, and an incident response plan are essential.

C. Cybersecurity is purely an IT issue, not a governance issue.

D. The auditor should not assess cybersecurity.

Q117 – Answer & Explanation

Correct Answer: B

Why: Cybersecurity is a board-level governance risk. Lack of expertise, reporting, and an incident response plan are significant governance deficiencies.

A wrong: Security is not solely an IT issue; governance oversight is required.

C wrong: Cybersecurity is a governance and enterprise risk.

D wrong: Internal audit assesses cybersecurity governance.

Q118

Question: An auditor is evaluating the organization's fraud risk assessment. Management's assessment is based solely on a brainstorming session with the CFO and controller, with no input from operations, sales, or IT, and no consideration of fraud schemes specific to the industry. Which conclusion is MOST appropriate?

A. The fraud risk assessment is adequate because senior finance staff participated.

B. The fraud risk assessment is deficient; it lacks cross-functional input and industry-specific fraud schemes.

C. The fraud risk assessment is adequate because brainstorming is a recognized technique.

D. Fraud risk assessment is not an internal audit concern.

Q118 – Answer & Explanation

Correct Answer: B

Why: Effective fraud risk assessment requires cross-functional input and consideration of industry-specific schemes. A finance-only brainstorm is insufficient.

A wrong: Finance-only input is too narrow.

C wrong: Brainstorming is useful but must be broad and informed.

D wrong: Internal audit assesses fraud risk (Standard 1210.A2).

End

End of Questions 60–118

Review, repeat, and mark weak areas.